

BEVEILIGINGS- PROBLEMEN BIJ REST-API'S

GDC - 2025 - 2026
Informaticawetenschappen - 6ICWE

Auteur:
Ian-Chains Baute

Mentor:
J. Gillis



• WAAROM DIT ONDERZOEK?

Maatschappelijke motivatie

- Softwarepakketten → complexer
- Digitale wereld → groeit
- Beveiliging → belangrijk → niet vergeten
- API's → veel gebruikt → data uit te wisselen

Persoonlijke motivatie

- Informatica wereld
- Uitwerken → projecten
- REST-API systemen gemaakt
- Nooit stilgestaan → beveiliging
- Info gebruiken → vervolg projecten



DE ONDERZOEKSVRAAG

Hoofdvraag

Welke beveiligingsproblemen komen voor bij REST-API's en hun authenticatiesystemen, en hoe kunnen deze worden voorkomen?

Deelvragen

- Welke beveiligingsproblemen komen voor?
- Wat houden deze beveiligingsproblemen in op technisch vlak?
- Hoe worden deze kwetsbaarheden misbruikt?
- Hoe kunnen deze kwetsbaarheden voorkomen worden?



HYPOTHESE

**XSS - Cross-Site Scripting
& CSRF - Cross-Site Request Forgery**



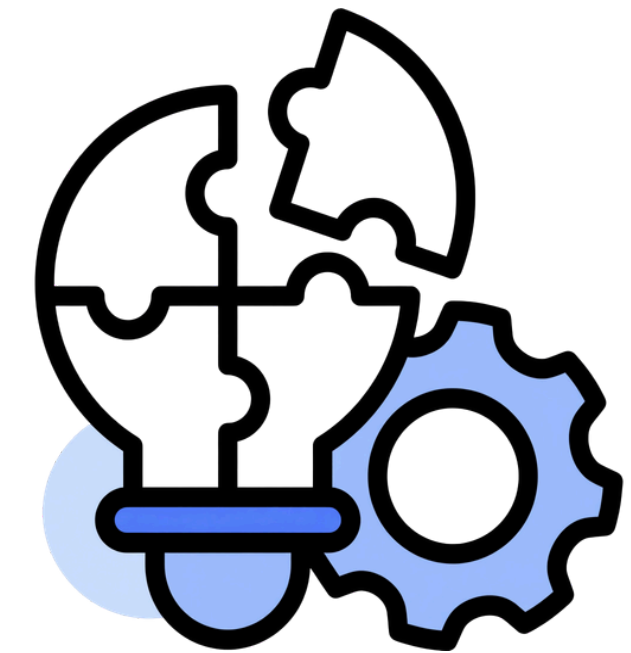
AANPAK & WERKWIJZE

Onderzoeksmethode

- Literatuurstudie → kennis & begrijpen
- Ontwikkелingsgedeelte & analyse
 - 2 API-systemen → veilige & onveilige
 - Beveiligingsproblemen → reproducen & voorkomen
- Betrouwbaar → kennis & info → praktisch

Bronnen

- Technische documentaties & artikels
 - Praktisch → bibliotheekdocumentatie
- Educatieve informatie video's
- Resultaten → analyse → eigen systeem



BEVINDINGEN & RESULTATEN

XSS - Cross-Site Scripting

- Verschillende soorten
 - Reflected XSS
 - Stored XSS
- Gevolgen
 - Session hijacking
 - Ongeautoriseerde acties
 - Content spoofing
 - ...
- Manieren → voorkomen
 - HTML Escaping
 - HTML Stripping
 - HTML Sanitization
 - HttpOnly Cookies



BEVINDINGEN & RESULTATEN

CSRF - Cross Site Request Forgery

- Gevolgen
 - Ongeautoriseerde acties
 - Accountovername
 - ...
- Bestaande implementaties → voorkomen
 - SOP
 - CORS
- Extra beveiligingen → voorkomen
 - SameSite Cookies
 - (Anti-)CSRF Tokens



ANALYSE

Interpretatie van bevindingen

- Misbruik → vertrouwen
- Software → geen controles → input
- Gevolgen → overlappen → catastrofaal
- Geen “one size fits all”
- Beste optie → afhankelijk → doelen & functies

Belangrijkste inzichten

- Beveiligingsmaatregelen → niet universeel
- Maatregelen combineren → één → onvoldoende
- Standaard maatregelen → onvoldoende
- Extra controles → maken verschil



BESLUIT

- Beveiliging → noodzaak → mogelijke gevolgen
- Zero trust
- Gebruiker → wantrouwen
- Controle → vertrouwen
- Validation & Sanitization
- Schadelijke inhoud?
- Bewuste actie?





REFLECTIE

Nieuwe inzichten

- Inhoudelijke kennis
- Belangrijk → thema begrijpen
- Kijken → verwachtingen
- Praktische uitvoering → versterkt

Verbeterpunten

- Beknopt samenvatten
- Minder langdradig → korte zinnen
- Sneller knopen doorhakken
- Planning & tijdsverdeling

REFLECTIE

Vervolg

- Educatief project
 - Inhoudelijke info → uitgebreide API
 - Project → grote omvang
- Verder onderzoek
 - Andere beveiligingsproblemen
 - Beveiligingsproblemen bij andere systemen



BEDANKT

Zijn er nog vragen?

